

SECURITY RESEARCH

Extracting ATT&CK from Real Advisories

A Leakage-Safe Benchmark and Backend-Model Comparison for TTP Ingestion

AEGIS Labs Research
Version 0.1 (draft) | July 2026

K3

open-weight backend matched the leader and beat the proprietary flagship

real > synthetic

only real advisories separate frontier models

0 leaked IDs

input sanitized so extraction is inference, not copy-paste

Table of Contents

- 1 Executive Summary
- 2 Provenance
- 3 What We Measured
- 4 Inline-ID Leakage
- 5 Synthetic Versus Real
- 6 Refusal Is Framing-Dependent
- 7 Reasoning Effort and Backend Selection
- 8 Correcting Non-Exhaustive Ground Truth
- 9 Takeaways
- 10 Artifacts and Limitations

1. Executive Summary

Threat-intelligence ingestion increasingly leans on a large language model to read an advisory and return the MITRE ATT&CK techniques it describes. Choosing which model to run for that step, and measuring how well any of them does it, turns out to be harder than it looks, and most of the difficulty is in the benchmark rather than the models.

We benchmark four frontier models (Claude Opus 4.8, Kimi K3, DeepSeek-V4-Pro, Qwen3-Max) on extracting ATT&CK techniques from threat reports, across a synthetic seed corpus and a corpus of 25 real CISA advisories. Four findings shape both how such a benchmark should be built and which model a production ingestion pipeline should use.

Key Findings

- **Inline-ID leakage.** CISA advisories cite technique IDs inline in the prose. If that text reaches the model unstripped, the benchmark measures copy-paste, not extraction, and every model scores near ceiling.
- **Synthetic corpora do not discriminate models; real advisories do.** All four models bunch at 0.84–0.93 F1 on clean synthetic vignettes but spread to 0.36–0.53 on real advisories, where a stable ranking finally emerges.
- **Refusal is framing-dependent, not content-dependent.** The strongest model refused a synthetic ransomware vignette but zero of 25 real advisories describing the same behavior.
- **Reasoning effort degrades extraction.** Raising a reasoning model from low to high effort cost 3x and lowered F1, by over-specifying correct parent techniques into wrong sub-techniques.

2. Provenance

The core evaluation methodology here, using CISA ATT&CK tables as document-level ground truth with a strict/substantiated split, coverage-delta reporting, and ground-truth re-vetting, is a sanitized public derivation of Adversarix's internal extraction-evaluation framework. This paper's new contributions are a more thorough input-sanitization step that removes every technique-ID token and table from the model input (not only bracketed citations), and the four-model comparison in Sections 5–7. All inputs are public: CISA advisories and publicly available models. No product internals are included.

3. What We Measured

Every model receives the identical prompt and returns the same JSON schema, a list of ATT&CK technique IDs plus supporting evidence, scored against gold labels. We report micro-averaged precision, recall, and F1 at two granularities: *strict* (exact ID) and *parent* (sub-technique collapsed to its parent). Two corpora carry the study: a *seed* set of 20 hand-authored synthetic vignettes, one clean intrusion chain each, and a *CISA* set of 25 real AA-series advisories whose gold is derived from each advisory's ATT&CK table, enterprise techniques only.

4. Inline-ID Leakage

CISA advisories tag behaviors with technique IDs inline in the narrative, for example “data exfiltration in bulk [T1114.002].” If the report text handed to the model contains those tokens, extraction collapses to copying them, and every model scores near ceiling regardless of capability. Because the same advisory text is both the model input and, through its tables and citations, the label source, input and answer key must be separated explicitly.

The trap is *partial* stripping. Removing the bracketed citation [T1114.002] but leaving the bare token T1114.002, or leaving the ATT&CK technique table in the input, still leaks the answer. Complete sanitization removes all three: bracketed citations, bare ID tokens, and the technique tables, while leaving the behavior description intact. After sanitization, zero gold IDs and zero technique-ID tokens of any kind remain in the prose across all 25 reports.

Why this is easy to get wrong

A benchmark that harvests labels from the advisory’s inline citations and then feeds the same advisory body to the model will report inflated, indiscriminating F1. The label pipeline and the input pipeline read the same tokens for opposite purposes; only the input side must be scrubbed.

5. Synthetic Versus Real

Corpus	Claude	K3	DeepSeek	Qwen3-Max	Spread
seed (synthetic)	0.906	0.927	0.844	—	0.08
CISA (real)	0.529	0.496	0.401	0.359	0.17

On synthetic vignettes the models sit within 0.08 F1 and the ordering is noisy. On real advisories every model roughly halves its F1 and the ranking becomes clear and stable: a bootstrap over the 25 reports puts Claude above K3 in 97% of resamples and K3 above DeepSeek in 100%. Clean, canonical synthetic corpora are a ceiling that cannot separate frontier models. Absolute F1 on real advisories is additionally deflated by non-exhaustive CISA tables (Section 8), so the ranking is more trustworthy than the absolute numbers.

6. Refusal Is Framing-Dependent

The strongest model refused exactly one seed report, a compact synthetic ransomware vignette, returning an empty output and zeroing its labels. On the 25 real CISA advisories, which describe the same and worse adversary behavior at far greater length, it refused nothing. The safety trigger tracked the terse “attack-recipe” framing of the synthetic vignette, not the underlying malicious content. For defensive pipelines this is reassuring, since real advisories pass, but operationally important: a refused report is silent data loss, so any pipeline routing through a frontier model needs explicit refusal detection.

7. Reasoning Effort and Backend Selection

Reasoning hurts this task. Raising Kimi K3 from low to high reasoning effort dropped strict F1 from 0.927 to 0.870 at 3x the cost and 3.5x the output tokens; the extra reasoning over-specifies correct parent techniques into wrong sub-techniques. Extraction is recognition, not multi-step reasoning, so reasoning-minimal settings are correct.

Model (CISA)	Strict F1	Recall	Errors	\$/report
claude-opus-4-8	0.529	0.554	0/25	0.092
kimi-k3-fireworks	0.496	0.477	0/25	0.034
deepseek-v4-pro	0.401	0.335	2/25	0.011
qwen3-max	0.359	0.290	1/25	0.007

The open-weight Kimi K3 lands within 0.03 F1 of Claude at a third of the cost, with zero refusals or malformed output, and it beat the proprietary Qwen3-Max outright. Both budget models emitted invalid JSON on the most technique-dense advisories, a reliability failure concentrated on exactly the hardest inputs. Per threat category the ranking holds uniformly, so there is no model-routing arbitrage, and difficulty is dominated by report type: every model scores about 0.6 on standardized ransomware advisories versus about 0.45 on bespoke nation-state reports.

8. Correcting Non-Exhaustive Ground Truth

CISA analysts tag a subset of techniques in the advisory table; the prose typically describes more, so a model extracting a real-but-untabled technique is scored a false positive, deflating precision to about 0.50 for all four models. The strict/substantiated split that addresses this, reporting F1 against all table labels and against only text-substantiated labels, originates in Adversarix's internal framework. We operationalize its label-vetting step as a released, reproducible adjudication tool: build a candidate pool per report (table gold union every model's predictions), surface the supporting prose per candidate, and have a human keep or drop each against the text with a substantiation tier. The emitted corpus reports a table-incompleteness delta, the techniques added or removed versus the CISA table, which both yields trustworthy absolute precision and recall and quantifies how incomplete auto-derived ground truth is.

9. Takeaways

- CISA-derived TTP benchmarks must strip inline ID citations, bare ID tokens, and technique tables from the model input.
- Evaluate on real advisories, not synthetic vignettes, and report a strict/substantiated split because table labels are not all extractable from text.
- For a TTP-ingestion backend, an open-weight model (Kimi K3 here) is the quality-per-cost pick; frontier reasoning and proprietary-flagship status did not help.
- LLM refusal on defensive-security content tracks framing; measure it on real data and handle it explicitly.

10. Artifacts and Limitations

The harness, the leakage-safe CISA ingest, and the adjudication tool are released under Apache-2.0/MIT in the AEGIS Labs `ttp-benchmark` directory, with 20 synthetic seed reports and 25 CISA advisories with gold labels. Twenty-five advisories is a small sample: the tier structure is robust, but the Claude-versus-K3 gap magnitude is not tightly bounded (overlapping bootstrap confidence intervals). CISA tables are non-exhaustive, as discussed. All numbers are point-in-time for the model versions listed and are not comparable across the two corpora.

Citation. Galappatti, K. (2026). *Extracting ATT&CK from Real Advisories: A Leakage-Safe Benchmark and Backend-Model Comparison for TTP Ingestion*. AEGIS Labs, Adversarix, Inc. github.com/Adversarix/aegis-labs

This whitepaper is released for public reference and citation. Reproduction in whole or in part requires attribution. No rights are granted to the underlying platform software or its implementation.